nos4a2 (Ângelo Azevedo) Day 1 CTF Writeups

1. OSINT

a. Fear

We had the original description (I don't have it anymore).

On Discord we got the clue:

```
Hint: A user with the name Maaasquerade did some unspeakable things in the darknest parts of the web you will find him soon!! He posted a message regarding the flag.
```

I then though "darkest parts" -> Twitter/X, I then used xcancel.com, an alternative front end to search for the username "Maaasquerade", but nothing.

I then saw the message on Discord from the creator of the chall:

```
@Player I will update the flag for Fear OSINT challenge since my account got banned I will ask for the remaining players who didn't  solve it to look again at what I am asking .
```

And saw the new description:

```
New flag format: I need you to find the url of the posts-endpoint site forum where the hacker got banned (Ex for format:https://somethingdeep.com/posts)
```

I then though about the dark web and went to the darknet forum dread, searched the user, created 1h ago and that url was the flag.

2. Forensics

a. DeadWeight

This was the last challenge that I did and I tried to do it in 15 minutes so I didn't got much, but got a flag.

Description:

```
Well, well, well... This one is tricky and hard to beat. Let's take a second to relax. Here it comes! I managed to delete THE flag from the system, muhahaha, but... I still remember the times when I used axel to get my beloved flag. Enough with the story—provide the answers to the questions below. File is:
https://mega.nz/file/O6BzGKTY#bssfLGqOF5wVWh6RVJOq-yN8CgAi2CNVVMWSkXas3PA
⬇ MD5(second flag)=b029aefa19e1889303614610be7d3295
```

I then used vol_analyzer from the volatility-toolkit to run every volatility module automatically.

The first question was:

```
What is the SID (Security Account Identifier) of the user who tried to delete the flag? (Ex. OmniCTF{ssid})
```

I went to the getssids.txt file from the getssids module, searched for a username possible, saw the user Masquerade and got the SSID from the user Masquerade S-1-5-21-3266328033-1872285240-1484667356-1001.

If I had more time I would search on the other module outputs to get the other answers asked.

b. QuackQuackDiriDiriDuck

On this one we were presented with a list of 6 eml files and a pcapng file. The first question was:

```
How many emails have malicious PDFs? (Example: OmniCTF{67})
```

I got this number by doing a “grep pdf *” inside the emls folder and it was 5.

The second question was:

```
What is the first malicious HTTP download URL in the PCAP? (Example: OmniCTF{url})
```

I then did the “What is the first malicious HTTP download URL in the PCAP? (Example: OmniCTF{url})” question by using the http filter on Wireshark and getting the first link.

After that I did the “At what timestamp is the malicious ZIP requested? (Example: OmniCTF{YYYY-MM-DD HH:MM:SS})”, by getting the UTC timestamp of that request on Wireshark.

“At what timestamp is the Qakbot DLL requested? (Example: OmniCTF{YYYY-MM-DD HH:MM:SS})” was done the same way, by getting the UTC timestamp of that request on Wireshark.

“How many unique remote IP-and-port combinations use the Qakbot TLS client fingerprint? (Example: OmniCTF{67})” I did by “bruteforcing” the number, starting with 1 and ending in the answer 4. I then trying to do the other ones found the 4 combinations and the 3 distinct ips.

The “Arrange the emails the attacker used to send the PDFs alphabetically from a -> z? (Example: OmniCTF{abc@andydwdhhdd.net+test@omnictf.com})” was broken when I tried it but I had all the e-mails just by filtering the headers on the files.

The “What malware family is represented? (Example: OmniCTF{Fam})” I thought that it was Qakbot but it was neither that nor any variation or alias.

3. Web

a. StayWild

I starting by exploring the website and trying the basic injections, XSS, SQLi. I got stuck for a while and moved away from this chall.

When I got back I tried fuzzing on the website to find hidden paths.

I ran:

```
ffuf -w /usr/share/seclists/Discovery/Web-Content/common.txt -u https://staywild-2a4f
107442c9.inst.omnictf.com/FUZZ
```

And found the path `/staging`:

```
:: Progress: [3978/4750] :: Job [1/1] :: 146 req/sec :: Duration: [0:00:26] :staging
[Status: 200, Size: 2113, Words: 442, Lines: 69, Duration: 224ms]
```

By accessing this page I got to a new page with the ability to submit a field archive.

I though that I could sent a script but the backend blocked any kind of file that not a tar file.

I then thought that I could try a zip slip attack to get the flag.

I created a test.tar file with an empty archive and sent it.

Got:

```
[extraction 1] initial archive pass
1.txt
```

With the file inside the tar. Got stuck again. After a lot of trying, I tried renaming the tar. I then ended up trying to run the path traversal using the tar name and tried to send a tar file called $(ls).tar, that would spawn a new shell process and run ls. Got:

```
[extraction 1] initial archive pass
tar: $(ls).tar.tar: Cannot open: No such file or directory
tar: Error is not recoverable: exiting now
```

Now I knew that I could execute commands in the backend. I tried to search for the flag on the current directory, nothing, got to the root, the other users folders and got nothig. Gave up for a while, went to do other challs, when I got back I looked at the text “Field bundles are unpacked in a controlled workspace before any extra material is attached to the report.” and thought about the /app folder. Searched for the /app folder and searched on a lot of files, then saw the Dockerfile and used the file “$(cd .. && cd .. && cd app && cat Dockerfile).tar” to get the flag. It was in base64 and it decoded to the flag.

b. Ganzir

On this chall I also tried the default, XSS, SQLi, then for a lot of time I didn’t see the text “Recovery bulletin: Cassie from Records has been assigned to the harness intake desk. Temporary access should use the identity relay.”. After noticing it I tried the “Recover access credentials” on the Cassie account. I tried to recover her credentials with BurpSuite, first with upper case, didn’t do nothing different, then with lowercase and got, on the response:


```
{
  "delivery": "site19-internal-mail",
  "message": "Recovery link sent to c***r@site19.int.",
  "ok": true,
  "relay_id": "Q-35AF0FF2",
  "smtp_trace":
"eyJyZWxheSI6IlEtMzVBRjBGRjIiLCJyY3B0IjoiY2Fzc2llLm1lcmNlckBzaXRlMTkuaW50IiwicHJldmlld191cmwiOiJodH
}
```


The smtp_trace was base64 that decoded to:


```
{"relay":"Q-35AF0FF2","rcpt":"cassie.mercer@site19.int","preview_url":"http://ganzir-
c528e5293439.inst.omnictf.com/reset/JKAKDBPCq5I3aCHdTnpEQfe0","retention":"debug-
preview-enabled"}
```


I then got the preview_url and used the “Reset access credentials” on the Cassie account, paste it on the browser and changed the cassie password to 123.

After logging in with cassise I searched for where I could do an injection, went to the Templates window, tried a SSTI, got the 49 and then noticed the helper function `read_file` and running `{{ read_file("/flag.txt") }}` got the flag.